Portfolio 2: Authentication Design Rationale

Carl Rundkvist & Holger M. Pedersen 03-02-2026

Indholdsfortegnelse

Summary 3
Identity Groups 3
Table of Authentication Mechanisms 4
Auth reduce risk or not 5
Link til Threat Model 5
Conclusion 6

Summary

Dette dokument viser designet af authentication metoderne for et universitets læringsplatform. Vi har reflekteret over vores beslutninger og beskrevet rationale bag dem. Derudover har vi sammenlignet med vores tidligere fremstillede STRIDE threat model, og produceret et nyt og forbedret data-flow-diagram. Dette har vi gjort for at medbringe alle nye roller som beskrives i dette dokument.

Identity Groups

• Studerende
Studerende som er i gang med en fuldtidsuddannelse. De er fysisk til stede på uddannelsen og har adgang til skolens online platform.

• Undervisere
Fuldtids undervisere som er fysisk til stede på skolen og underviser. De har adgang til skolens online platform.

• Forsknings og adjunkt personale
Personalets primære arbejde er forskning, men kan også være ind over undervisning som gæstelektor (adjunkt). De har adgang til skolens online platform, samt forsknings platform.

• Service desk
Service desk som primære arbejde er at støtte de studerende i deres studie. De har admin adgang til skolens online platform.

Table of Authentication Mechanisms

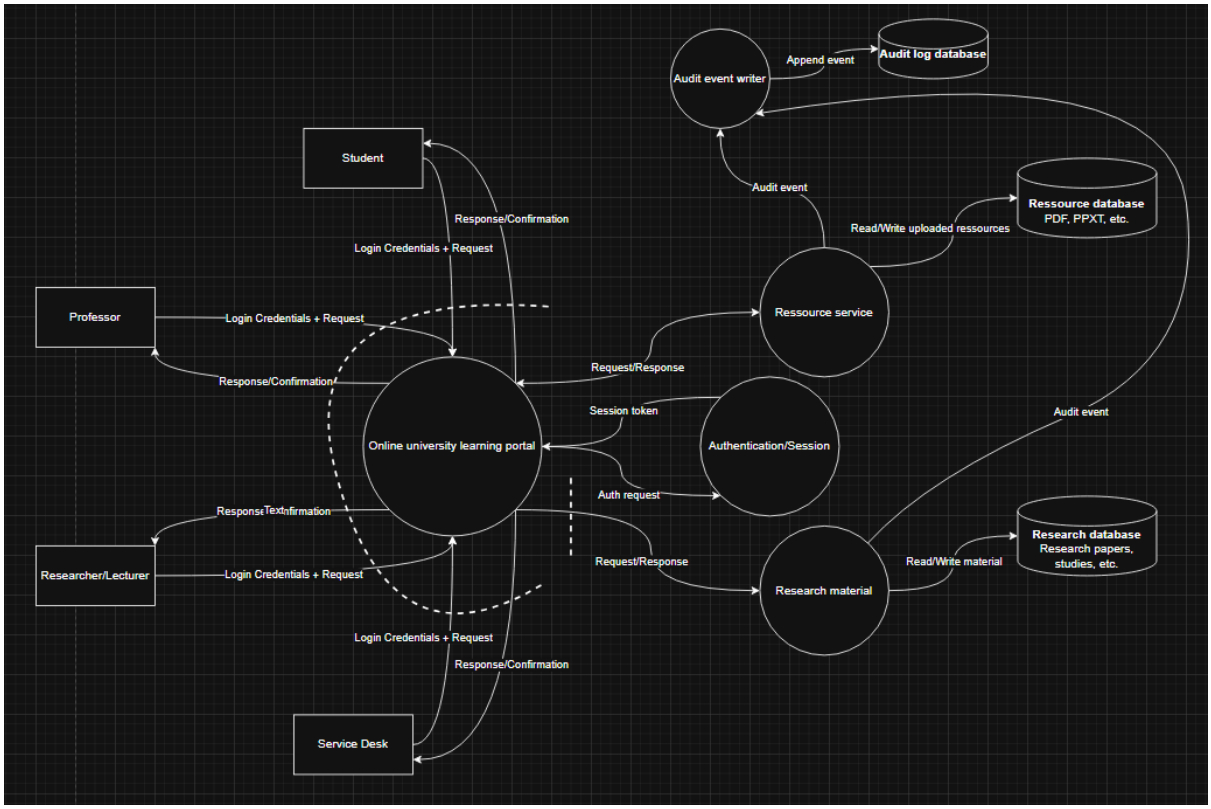
Identity Group	Authentication Method	MFA Required	Justification
Studerende (Fuldtid)	Brugernavn + Password + (External authenticator app)	Optional / Conditional	MFA er obligatorisk hvis studerende skal have adgang til forskningsdata. MFA er også obligatorisk hvis den studerende skal ændre på sensitive oplysninger.
Undervisere (Fuldtid)	Brugernavn + Password + External authenticator app	Ja	MFA er obligatorisk for undervisere, da de har højere privilegier, og kan udgive undervisningsmateriale. Det er vigtigt at en undervisers konto ikke bliver kompromitteret så f.eks. undervisningsmateriale bliver slettet
Forsknings og adjunkt personale	Brugernavn + Password + External authenticator app	Ja	MFA er obligatorisk for forsknings personale fordi de har adgang til at tilgå og uploade forskningsdata som kan være værdifuldt. MFA er obligatorisk af samme grund som forskningspersonale og undervisere, da de fungerer som en sammensætning af disse.
Service Desk	Brugernavn + Password + External authenticator app	Ja	MFA er obligatorisk for service desk da de er administratorer i skolens online system og kan foretage ændringer på root niveau.

Auth reduce risk or not

Authentication reducerer risici for at uautoriserede brugere får adgang, ved at kræve at undervisere, forskningspersonale, adjunkt, og service desk skal bruge ekstern app login for at tilgå onlineportalen. Vi har valgt estern applikation da det er en sikker relativt let løsning, som ikke kræver meget fra medarbejderne.

Authentication hos de studerende er stadig vigtig for at folk som ikke går på skolen, ikke kan tilgå de studerendes konti. Dog er de oplysninger eller permissions som studerende konti har, ikke kritiske nok til at kræve MFA. Her er det et valg for at balancere usability frem for sikkerhed.

Link til Threat Model



Studerendes krav om/valgfrie multi factor authentication kan linkes op på spoofing truslen i STRIDE threat model. Her kan en “Hacker”/ekstern aktør udgive sig for at være en elev med elevens login credentials, og på den måde få adgang til noget data som de ikke er authorized til. Det er dog ikke nødvendigvis følsomme data. Derfor er MFA optionel, medmindre den studerende har udvidede privilegier.

Undervisere har krav om multi factor authentication da de har privilegier og adgang til at udgive, redigere og slette undervisningsmateriale, samt læse og give feedback

på afleverede projekter. Dette kan linkes op på Tampering i Stride hvis undervisernes login bliver Spoofed. Dette betyder altså et krav om MFA.

For forsknings- og adjunkt personale gælder samme krav som for undervisere. De har adgang til værdifulde data og der er en trussel i Spoofing samt Tampering. Derfor MFA required.

For service desk gælder også krav om multi factor authentication. De fungerer som administratorer på platformen, og i tilfælde af Spoofing opstår der også en trussel for Tampering og Information Disclosure. Da service desk har adgang til personfølsomme oplysninger om de enkelte studerende og undervisere.

Conclusion

Flere steder opstår der en konflikt mellem brugbarhed (ease of use) og sikkerhed. Vi vurderede, at det er uundgåeligt og skabe et sikkert arbejdsmiljø uden at kompromittere brugbarheden.
Når der er krav om multi factor authentication, vil der altid være nogen som prøver at modarbejde det, på grund af dovenskab eller andre årsager. Men sagen er, at uden MFA stiger truslen for spoofing, og der findes ikke umiddelbart nogle løsninger som påvirker brugbarheden mindre og samtidig giver et tilfredsstillende sikkerhedsniveau. Så kender vi det i hvert fald ikke.

Vi har vurderet, at den gruppe som mest sandsynligt vil prøve at omgå disse sikkerhedsforanstaltninger, er de studerende. De er sandsynligvis mest tilbøjelige til at have så nem adgang som muligt, altså ikke opsætte MFA selvom de bør.

De risici fra STRIDE som vi ikke har berørt i denne opgave er Elevation of Privilige, Denial of Service og Repudiation. For disse gør MFA ikke nogen forskel. Her er der tale om fejl i brugerstyring, manglende håndtering af mange requests og dårlig logging.